COMPLIANCE & SECURITY · CHECKLIST

Vendor Risk Review Checklist

For operations and technical leaders who need a fast, consistent way to assess third-party tools, including AI vendors, before and after they're connected to company data.

> **How to use this:** Tier each vendor by what it touches, apply the matching level of review before signing up or renewing, and add the AI questions for any vendor with AI features.

Vendor Tiering

Sort current and prospective vendors into tiers based on what they can access.

Vendor	What it touches	AI features? (Y / N)	Tier (Critical / Standard / Low)	Last reviewed

Core Review Questions (Critical and Standard Tier Vendors)

- [ ] What specific data can this vendor access, and is that access scoped to only what's needed?
- [ ] Where is the data stored, and does that location matter for our customers' requirements?
- [ ] Does the vendor have a public security page, certification, or documented security posture?
- [ ] What is the vendor's process and timeframe for notifying us of a security incident?
- [ ] Does the vendor's own subprocessor list introduce any additional risk we should know about?
- [ ] What happens to our data if we cancel? Is it deleted, exportable, or retained?

AI Vendor Questions

Add these for any vendor whose product includes AI features, including features switched on in a later update.

- [ ] Is our data, including prompts, files and outputs, used to train or improve any model? Is the answer in the contract, not just the FAQ?
- [ ] How long are prompts, outputs and logs retained, and in which country?
- [ ] Which model providers sit behind the product, and will we be told before that changes?
- [ ] Can AI features be switched off, or limited to certain data, at our account level?

© 2026 Rev-IQ. Free to use and adapt.

- [ ] Does the product make or substantially inform decisions about individuals? If so, what do we need to disclose?
- [ ] How does the vendor test for and handle wrong outputs, prompt injection and data leakage?
- [ ] Does the vendor hold, or plan to hold, ISO/IEC 42001 or a comparable AI governance attestation?

Contract Clauses to Ask For

For critical-tier and AI vendors. Your lawyer will adapt the wording; this is the list to raise.

Clause	What it should say
No training	Our data, prompts and outputs are not used to train or improve models without written consent.
Retention and deletion	Defined retention for prompts, outputs and logs, and deletion on request or termination.
Incident notification	A specific notice period that leaves us time to meet our own regulatory deadlines.
Subprocessor change notice	Advance notice of new subprocessors or model providers, with a right to object.
Decision transparency	Enough information about automated decision features for us to meet our own disclosure obligations.
Evidence and audit	Access to security reports, certifications or questionnaire answers on request.

Operational Dependency Check

How critical is this vendor to a core workflow? What breaks if it goes down for a day?

How difficult would it be to replace this vendor if pricing, features, or terms changed unfavourably?

Has an alternative ever been evaluated, even informally?

Low-Tier Vendor Fast Check

- [ ] Vendor does not have access to customer data, source code, or payment information.
- [ ] Vendor is used by a limited number of people for a non-critical function.
- [ ] Vendor has no AI features that can reach company data, or those features are switched off.

New Vendor Intake Habit

- [ ] New vendors are checked against this tiering before being connected to real data.
- [ ] Critical-tier vendors require sign-off from a named person before go-live.
- [ ] Vendor list and tiers are revisited at least twice a year, and whenever a vendor adds AI features.

© 2026 Rev-IQ. Free to use and adapt.

- [ ] Any vendor with a known incident or acquisition is re-reviewed promptly.

Where This Maps

Framework or obligation	Where this resource lines up
ISO/IEC 27001:2022 Annex A	5.19 to 5.22 supplier relationships, agreements, ICT supply chain and monitoring; 5.23 cloud services
ISO/IEC 42001 Annex A	A.10 third-party and customer relationships
ASD Essentials for enterprise IT	Cyber supply chain security
Australian Privacy Act	APP 1.7 to 1.9: OAIC guidance says entities should understand how third-party programs make or assist decisions
UK GDPR	Article 28 processor contracts

General guidance, not legal advice. References to standards show where this resource aligns; using it does not make an organisation compliant or certified. Check your specific obligations with a qualified adviser. Regulatory references checked October 2026.

© 2026 Rev-IQ. Free to use and adapt.